RAPPORT DE SYNTHÈSE

Sécurisation des bases de données biométriques à iris

Version courte et accessible — sans code informatique

Réalisé par

Koffi ADJOVI

Aïcha SOSSOU

Novembre 2026

Code source et rapport technique complet : https://github.com/lionelazlok/iris

Le projet en une page

Le problème

Les systèmes de reconnaissance par l'iris gardent une « empreinte numérique » de l'œil de chaque personne dans une base de données. Si cette base est volée, le dommage est **définitif** : on peut changer un mot de passe, pas son iris.

Notre réponse

Nous avons conçu et programmé un système qui **ne garde jamais ni la photo de l'œil, ni son empreinte lisible**. Ce qui est stocké est brouillé, puis chiffré : volé, il est inutilisable. Chaque accès est contrôlé et enregistré dans un journal impossible à falsifier sans que cela se voie.

Ce que montrent nos mesures

- **0 erreur** d'acceptation : aucun imposteur accepté sur 2450 tentatives.
- **1 seul refus à tort** sur 300 vérifications de vraies personnes.
- La protection **ne dégrade pas** la reconnaissance et ne coûte presque rien en temps de calcul.
- Les **10 attaques** simulées sur la base de données ont toutes été bloquées ou détectées.
- Réserve : les tests ont été faits sur des **images d'iris générées par ordinateur**, plus faciles que des photos réelles.

1. Pourquoi protéger une base d'iris ?

La biométrie, c'est reconnaître une personne à une caractéristique de son corps : empreinte digitale, visage, voix ou iris. L'iris, la partie colorée de l'œil, est l'une des plus fiables : son motif est unique, même chez de vrais jumeaux, et il reste stable toute la vie.

Cette fiabilité a un revers. Ce que l'on stocke est un **identifiant à vie**. Or des fuites massives ont déjà eu lieu :

- **2015, États-Unis** : 5,6 millions d'empreintes digitales de fonctionnaires volées (fuite de l'OPM).
- **2019, Biostar 2** : une base de contrôle d'accès retrouvée en ligne, avec plus d'un million d'empreintes non chiffrées.

Une comparaison simple

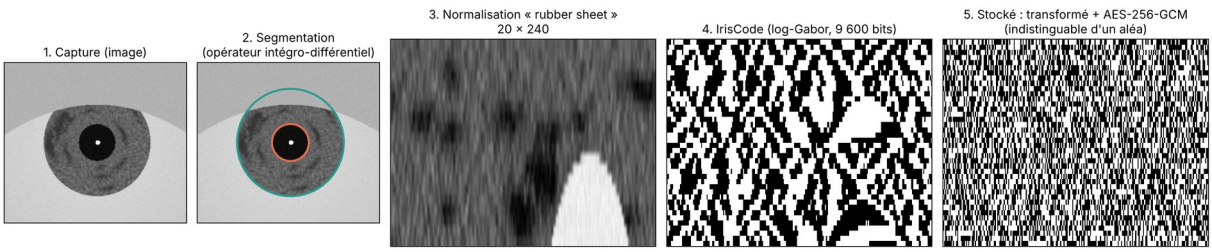
Mot de passe volé → on le change, l'incident est clos.

Iris volé → impossible à changer ; la personne reste exposée sur tous les systèmes qui utilisent son iris.

La loi en tient compte. Le RGPD classe les données biométriques parmi les données **sensibles**, qui exigent des protections renforcées. La norme internationale ISO/IEC 24745 demande trois propriétés à une base biométrique protégée :

Exigence	En clair
Irréversibilité	À partir de ce qui est stocké, on ne doit pas pouvoir retrouver l'iris.
Non-liabilité	On ne doit pas pouvoir reconnaître la même personne d'une base à une autre.
Révocabilité	Si une donnée fuit, on doit pouvoir l'annuler et en émettre une nouvelle.

2. Comment un ordinateur reconnaît un iris



Les étapes, de la photo à ce qui est réellement stocké.

Étape	Ce qui se passe	Pourquoi
1. Photo	L'œil est photographié.	Point de départ.

2. Repérage	Le logiciel trouve deux cercles : le bord de la pupille et le bord de l'iris.	Isoler l'anneau coloré.
3. Dépliage	L'anneau est « déroulé » en un rectangle, comme on déplie un bracelet.	Comparer des yeux plus ou moins dilatés.
4. Code	Le motif est résumé en 9 600 cases noires ou blanches : l'**IrisCode**.	Comparer vite et précisément.
5. Stockage	Le code est brouillé puis chiffré : il ressemble à du bruit.	Le rendre inutile en cas de vol.

Pour comparer deux yeux, on compte le pourcentage de cases différentes entre leurs codes ; c'est la « distance de Hamming ». Pour deux yeux différents, environ la moitié des cases diffèrent (≈ 0,50), comme si l'on tirait à pile ou face. Pour le même œil photographié deux fois, peu de cases diffèrent (≈ 0,15). **En dessous de 0,34, nous concluons qu'il s'agit de la même personne.**

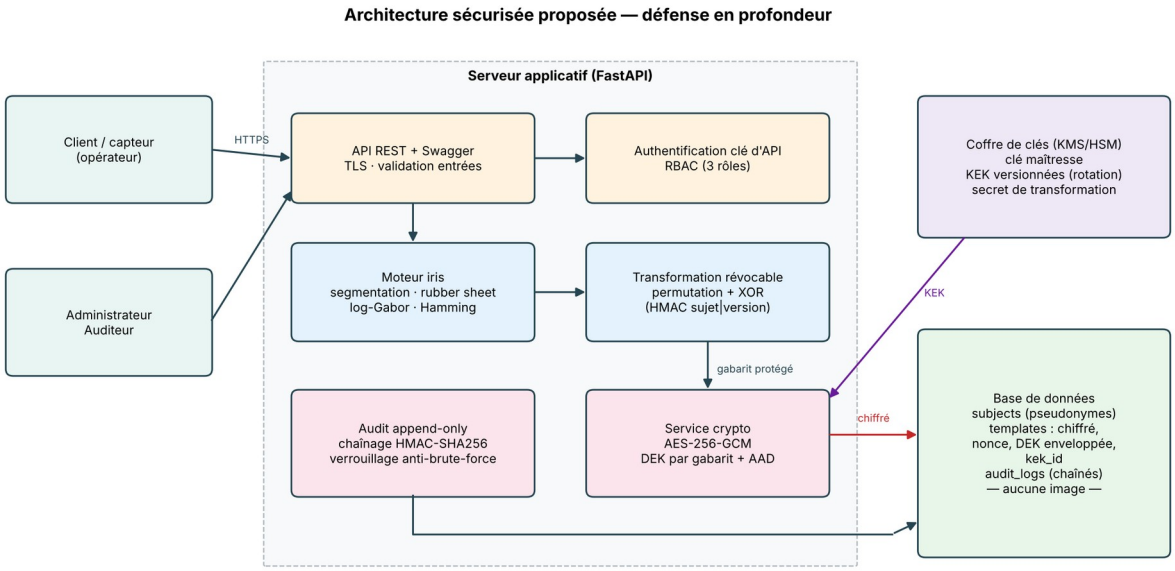
3. Les dangers qui menacent la base

Menace	Ce que ça veut dire	Notre parade
Vol de la base	Quelqu'un copie le fichier de données.	Tout est chiffré : la copie est illisible.
Reconstruction de l'œil	Des chercheurs ont montré qu'on peut recréer une image d'iris à partir de son code.	Le code n'est jamais stocké en clair.
Substitution	L'attaquant remplace l'iris de la victime par le sien pour entrer à sa place.	Chaque donnée est scellée à sa ligne : l'échange est détecté.
Recoupement	Retrouver la même personne dans plusieurs bases.	Chaque base et chaque version brouillent différemment.
Abus interne	Un employé consulte ou modifie ce qu'il ne devrait pas.	Rôles séparés et journal de tous les accès.
Effacer ses traces	Modifier le journal après une intrusion.	Journal chaîné : toute retouche se voit.
Essais répétés	Présenter des centaines d'images pour finir par passer.	Blocage après 5 échecs.

4. Notre solution : cinq couches de protection

Le principe est celui de la **défense en profondeur** : si une protection cède, les autres tiennent encore. On peut comparer le système à une banque, qui combine un coffre, des clés gardées ailleurs, des badges et des caméras.

Couche	Image	Ce qu'elle fait
1. Brouillage révocable	Un code secret propre à chaque personne	Le code de l'iris est mélangé selon une recette secrète. La comparaison reste aussi précise, et en cas de fuite on change de recette (on « révoque »).
2. Chiffrement AES-256	Le coffre-fort	Le code brouillé est chiffré avec un standard reconnu mondialement. Toute modification, même d'un seul bit, est détectée.
3. Gestion des clés	Les clés rangées dans une autre pièce	Les clés ne sont pas dans la base. Chaque personne a sa propre clé, et les clés peuvent être renouvelées sans réenregistrer personne.
4. Contrôle d'accès	Les badges	Trois profils : l'opérateur enregistre et vérifie, l'auditeur consulte les traces, l'administrateur gère les clés et les suppressions.
5. Journal infalsifiable	La caméra de surveillance	Chaque action est enregistrée. Chaque ligne est liée à la précédente comme les maillons d'une chaîne : en retoucher une casse la chaîne.



Vue d'ensemble du système.

Ce que le système ne garde jamais : la photo de l'œil, le code lisible de l'iris et le nom de la personne (seul un identifiant anonyme, par exemple « EMP-001 », est conservé).

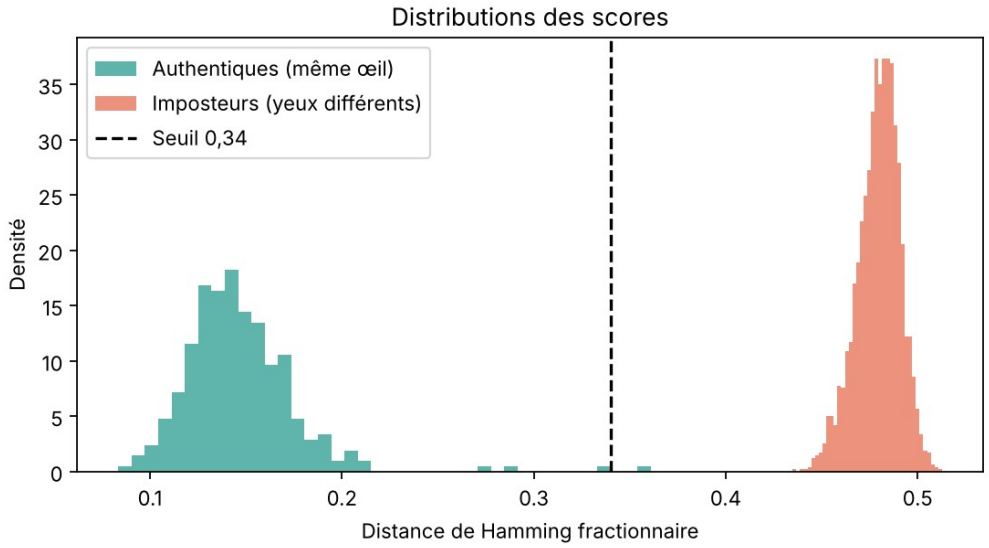
5. Comment nous avons testé

Nous avons réalisé un **prototype qui fonctionne réellement** : un service web qui enregistre et vérifie des personnes, testable depuis un navigateur. Pour l'évaluer :

- **Images** : 50 « personnes » × 4 photos = 200 images générées par ordinateur, avec des variations réalistes (œil tourné, pupille dilatée, éclairage, flou, paupière, reflet). Les bases de photos réelles exigent une licence que nous ne pouvions pas obtenir à temps.
- **Fiabilité** : 300 comparaisons entre photos d'une même personne et 2450 entre personnes différentes.
- **Sécurité** : 30 tests automatiques, dont 10 où nous jouons le rôle d'un pirate qui a accès à la base.

6. Résultats

6.1 Le système reconnaît-il bien les personnes ?



Répartition des scores de comparaison.

Comment lire ce graphique

• **Montagne verte** (à gauche) : comparaisons d'une personne avec elle-même ; les scores sont bas, autour de 0,15.

• **Montagne orange** (à droite) : comparaisons entre personnes différentes ; les scores sont proches de 0,48.

• **Ligne pointillée** : notre seuil de décision (0,34). À gauche on accepte, à droite on refuse.

• Plus l'écart entre les deux montagnes est grand, plus le système est fiable. Ici, elles ne se chevauchent pas.

Indicateur	Résultat	Interprétation
Imposteurs acceptés (FAR)	0 sur 2450	Aucune fausse personne n'est entrée.
Vraies personnes refusées (FRR)	1 sur 300 (0,33 %)	Une personne aurait dû réessayer (œil très tourné).

Échecs d'enregistrement	0 sur 200	Toutes les images ont pu être traitées.
Rotation de l'œil tolérée	jusqu'à environ 12°	Au-delà, il faut redemander une photo.
Temps d'une vérification	≈ 30 millisecondes	Instantané pour l'utilisateur.

6.2 La protection a-t-elle un coût ?

Question	Réponse mesurée	Interprétation
Le brouillage change-t-il les scores ?	Écart de 0	La reconnaissance reste exactement aussi précise.
Combien de temps prend le chiffrement ?	6,6 µs (millionièmes de seconde)	≈ 0,02 % du temps total : négligeable.
Quelle place en plus sur le disque ?	+88 octets par personne	+3,7 % : négligeable.

6.3 Les attaques sont-elles arrêtées ?

Ce que fait le pirate	Ce qui se passe	Bilan
Ouvre le fichier de la base	Il ne voit que des données illisibles, aucune photo.	✔️ Protégé
Modifie un seul bit d'une donnée	Alerte d'intégrité, vérification refusée.	✔️ Détecté
Met son iris à la place de celui de la victime	Alerte d'intégrité, accès refusé.	✔️ Détecté
Tente d'ouvrir le coffre avec une mauvaise clé	Ouverture refusée.	✔️ Bloqué
Se connecte sans autorisation	Accès refusé, tentative enregistrée.	✔️ Bloqué
Opérateur qui veut lire le journal	Refusé : ce n'est pas son rôle.	✔️ Bloqué
Essaie 5 fausses images de suite	Compte bloqué 15 minutes.	✔️ Bloqué
Transforme un « échec » en « succès » dans le journal	La chaîne est cassée, la ligne modifiée est pointée.	✔️ Détecté
Supprime une ligne du journal	Trou dans la chaîne détecté.	✔️ Détecté
Réutilise une donnée annulée	Refusée ; l'ancienne et la nouvelle ne se ressemblent pas.	✔️ Bloqué

7. Ce que le système ne garantit pas

Aucun système n'est sûr à 100 %. Voici, en toute transparence, ses limites :

Limite	Explication simple	Piste d'amélioration
Images de synthèse	Les vraies photos (cils, flou, lunettes) sont plus difficiles : les vrais taux d'erreur seraient plus élevés.	Tester sur une base réelle (CASIA, ND-IRIS).
Moment de la comparaison	Pendant quelques millisecondes, le code est déchiffré dans la mémoire du serveur.	Comparer dans une puce sécurisée ou sur données chiffrées.
Recette de brouillage	Si un pirate vole à la fois la base et la recette, le brouillage peut être défait (le chiffrement reste).	Garder les secrets dans un boîtier matériel dédié (HSM).
Dernières lignes du journal	Supprimer les toutes dernières lignes peut passer inaperçu.	Copier régulièrement l'empreinte du journal ailleurs.
Faux iris imprimé	Détecter une photo ou une lentille présentée au capteur n'était pas dans notre périmètre.	Ajouter une détection de vivacité.

8. Conclusion

Une base biométrique doit être conçue **comme si elle allait un jour être volée**. En empilant cinq protections complémentaires, notre prototype garantit qu'un vol de la base ne livre ni photo ni code d'iris exploitable, qu'une donnée compromise peut être annulée et que toute manipulation est repérée. Tout cela sans perte de précision et pour un coût de calcul négligeable. La prochaine étape serait une validation sur des photos réelles et l'utilisation de matériel de sécurité dédié.

Glossaire

Terme	Définition simple
AES-256-GCM	Méthode de chiffrement standard et très robuste, qui détecte aussi toute modification des données.
Biométrie	Reconnaissance d'une personne par une caractéristique physique (iris, empreinte, visage…).
Chiffrement	Transformer des données pour qu'elles soient illisibles sans la clé.
Clé (KEK, DEK)	Secret qui permet de chiffrer et de déchiffrer. La DEK protège une donnée, la KEK protège les DEK.
Distance de Hamming	Pourcentage de cases différentes entre deux codes d'iris : 0 = identiques, 0,5 = sans rapport.
FAR / FRR	Taux d'imposteurs acceptés à tort / taux de vraies personnes refusées à tort.
Gabarit	Résumé numérique de l'iris, ce qui est stocké à la place de la photo.

HSM / KMS	Boîtier matériel ou service spécialisé qui garde les clés en sécurité.
IrisCode	Code de 9 600 cases noires ou blanches qui résume le motif d'un iris.
Journal d'audit	Registre de toutes les actions effectuées sur le système.
RGPD	Règlement européen sur la protection des données personnelles.
Révocation	Annuler une donnée biométrique compromise et en créer une nouvelle, différente.
Rotation des clés	Remplacer périodiquement les clés de chiffrement par de nouvelles.

Pour aller plus loin

- Code source, guide d'installation et rapport technique complet : **https://github.com/lionelazlok/iris**
- Daugman J. (2004), How iris recognition works, IEEE TCSVT 14(1).
- Ratha N. et al. (2001), Enhancing security and privacy in biometrics-based authentication systems, IBM Systems Journal 40(3).
- ISO/IEC 24745:2022, Protection des informations biométriques · Règlement (UE) 2016/679 (RGPD).